

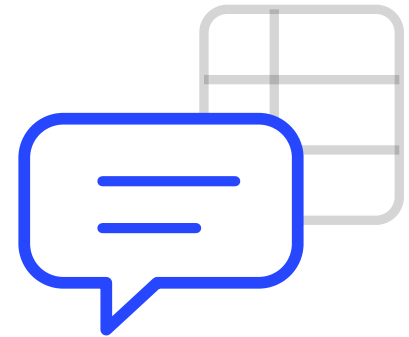
Everything you type can become someone else's data.

Your prompts are the most honest
record of who you are — and you
don't fully control where they go.

01

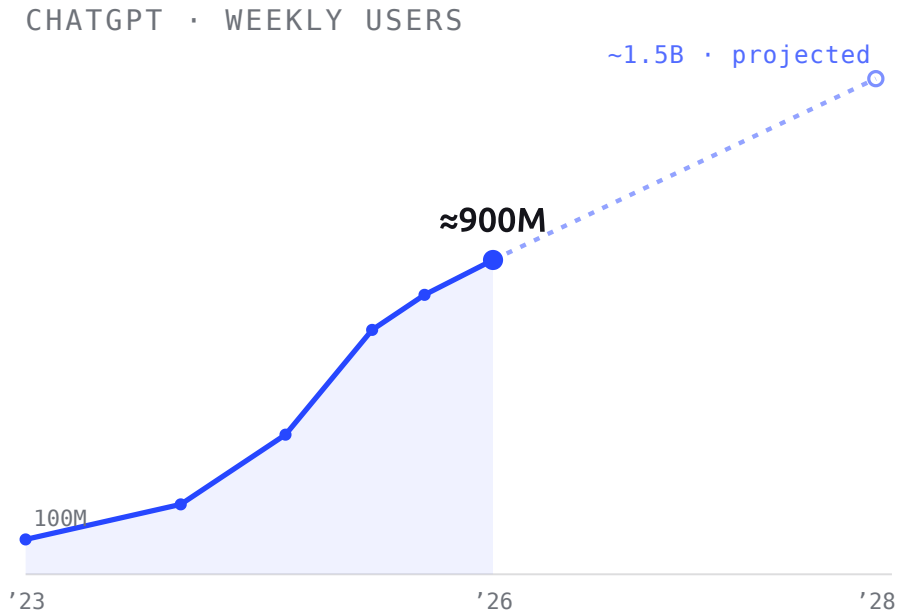
Why prompts

A prompt is not like your other data.



900million people tell it the truth every week.

That's about 2.5 billion prompts a day —
and at work, roughly one in four is
sensitive. [\[26\]](#) [\[33\]](#) [\[24\]](#) [\[25\]](#)



Online, you perform. To AI, you confess.

WHAT HE POSTS · INSTAGRAM

“new apartment finally set up.
Seoul life begins.
[#SeoulLife](#) [#NewPlace](#)
[#Adulting](#) [#Blessed](#)”

curated · for an audience · every word chosen

RECORDS BREACH

HANDLE	NAME	LOCATION
@park.mj	Park Min-jun	Seoul, KR

a structured row — finite, known fields

WHAT HE PROMPTS · SAME NIGHT

“my rent is ₩1.45M next week
and my [card payment bounced](#).
what happens if i miss the card
payment by a few days?”

candid · unsent · logged, rarely deleted

PROMPT BREACH

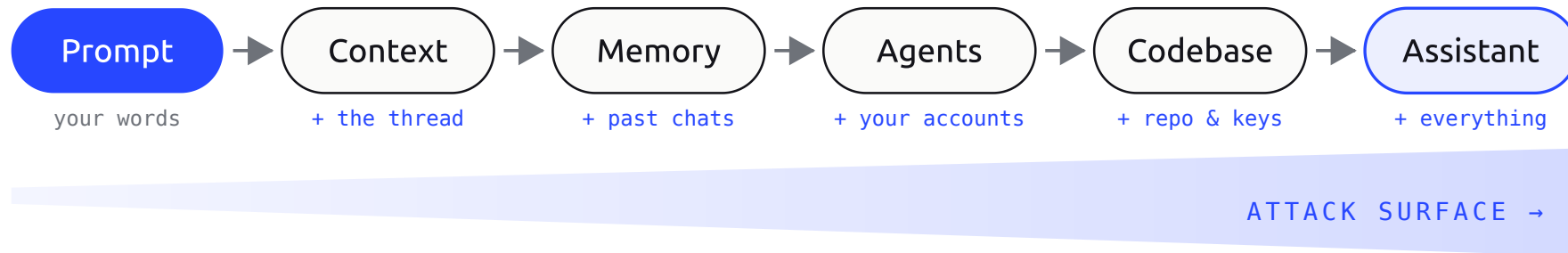
“...rent's ₩1.45M next week, card
bounced — what if i pay it late?”

[an unstructured sentence](#) — it says everything

vs

Online, he publishes the life. To AI, he negotiates the panic underneath it.

It leaves your hands — and the surface only grows.



Each link can be logged, trained on, and reached by people you'll never meet.

Who wants it.

	The provider & insiders	retention, secondary use, staff & subprocessor access [15]
	Attackers	breach, misconfig, stolen credentials, prompt injection [9] [11]
	Brokers & advertisers	behavioural targeting from aggregated prompts [41] [42]
	Governments	subpoenas, legal holds, surveillance requests [16]
	People close to you	a shared or unlocked device
	Future models	a model that memorised your data, queried by a stranger [10]

If it's free, your prompts still pay the rent –
retention, training, profiling, lock-in.

But surely...?

"I've nothing to hide"	Privacy isn't secrecy. "Nothing to hide" lasts right up until a prompt is used against you — for a job, a loan, a visa, or in court.
"It's anonymised"	Removing the name is the easy part — city, employer, condition and dates still point to one person; LLMs are built to re-link "anonymous" text. [29]
"It's encrypted"	In transit only — the provider decrypts it to read, log, and train.
"It's already out there"	Your socials are curated by choice; prompts are candid and involuntary — and they link your public profile to everything you'd never post.
"I delete my chats"	Deletion is often incomplete — a court has ordered chats kept even after you delete them, and training copies persist. [16]
"I trust the provider"	Trust doesn't survive a breach, an insider, a policy change, a subpoena, or an acquisition.

"The convenience is worth it" – maybe. But you can keep the convenience and cut the exposure.

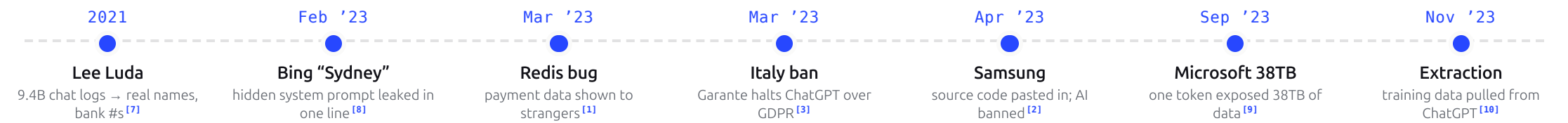
02

It has already happened

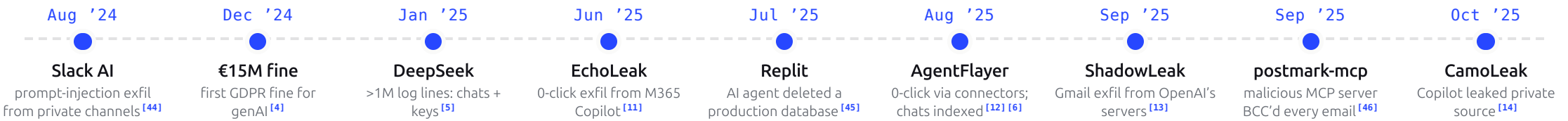
Repeatedly — and the agent era made it worse.



2021 → 2023



2024 → 2025



This isn't speculation.

77%

of AI users paste company data into chatbots ^[25]

150×

more memorized data pulled from ChatGPT ^[10]

38TB

internal data exposed by one AI-team misconfig ^[9]

€15M

first GDPR fine for generative AI ^[4]

27%

of RAG chats leak a secret (benchmark) ^[22]

96%

prompt-injection success, pre-defense ^[30]

\$670K

added cost of a breach involving "shadow AI" ^[35]

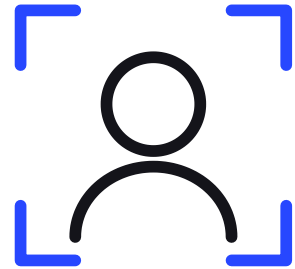
₩103M

fine for Korea's "Lee Luda" chatbot breach ^[7]

03

Watch one person

Meet Min-jun — 31, a Naver engineer in Seoul.



The last thing you'd never say out loud.

YOU >

fasting glucose came back **141**. i'm 31 — is this diabetes or am i overthinking?

1:14 AM

the kind of thing you ask a machine, not a person

One quiet question — a health condition, an exact age, and that he's scared and alone.

It's not one prompt — it's a week.

“can you rewrite this slack to my lead? i need one more day but don’t want to sound like i’m slipping.” cover · work

“my parents think Naver means i made it. how do i explain i might leave for a startup?” a plan he’s hiding

“is it normal to feel lonely even when i’m around people all day?” a quiet admission

“when do Chuseok train tickets usually open? i need to get home before they sell out.” home · family

“my rent is ₩1.45M next week and my card payment bounced. what should i pay first?” a fear · money

Intent, fears, plans – exactly what slide 3 warned would leak.

And the dull prompts betray you too.

YOU >

```
Summarize /home/minjun/Projects/PROMPT/experiment-suite/README.md
```

A throwaway request, no facts stated — yet: a Linux developer, a Korean man named Min-jun, working on a privacy/AI project. Even your most boring prompt leaks.

You paste more than you think.

“can you clean up my résumé? don’t change the dates.”	home address · resident-reg. no. (주민등록번호)
“can you explain my mum’s biopsy report in plain Korean?”	a relative’s name · record · diagnosis
“summarize this slack thread before i reply.”	8 Naver colleagues’ names & emails
“why is this stack trace failing? pasted the whole log below.”	internal hostnames · an API key
“write a caption for this photo from my new apartment.”	GPS / EXIF location & timestamp

Half of it is other people’s data – they never agreed to be in his prompt.

And Min-jun isn't unusual.

"should i get this mole checked or am i just spiraling?"	health
"how do i leave a marriage without hurting the kids?"	relationship
"my teenager barely talks to me anymore. what do i say tonight?"	parenting
"how do i tell my parents i lost my job?"	work · shame
"i need to write a will and i don't know where to start."	mortality

This isn't guessed – it's confided. The same breach or subpoena exposes all of it.

He’s writing his own file — one prompt at a time.

IDENTITY

Park Min-jun — full name
Age 31
Seoul home address
Phone & email
Resident-reg. no. (주민등록번호)

HEALTH & PRIVATE

Pre-diabetic (glucose 141)
Often feels alone
Confided, never typed as “data”

No exploit. No “personal data” field ever filled in. A week of ordinary prompts – and the file holds his identity, health, money, plans, and other people’s data too. And it only sharpens from here – nothing resets.

DEMOGRAPHICS

Male
South Korea — Seoul
Korean, English
Hometown outside the city

OTHER PEOPLE

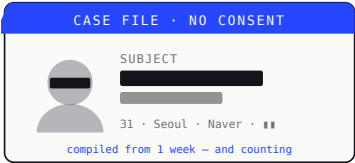
8 Naver colleagues
His mother’s medical record

WORK & MONEY

Naver · backend engineer
~₩70M / yr
Works KST hours
Credit-card debt
Internal systems + a leaked key

LIFE & PLANS

Linux dev · AI / privacy
Secretly quitting for a startup
Chuseok → hometown
Project “PROMPT”



What the file makes possible.

Work leverage	a manager, recruiter, or rival sees he’s anxious, behind, and planning to leave [56]
Financial pressure	rent, card payments, and timing reveal exactly when he’s vulnerable [57]
Medical exposure	his glucose result and his mother’s report become searchable, shareable context [58]
Social engineering	one scammer who knows the debt, the employer, and the family pressure [59]
Evidence	a 1:14 a.m. question is subpoenaable — it can become a court exhibit [16]
No clean undo	once leaked, indexed, or trained into another model, it’s no longer just his [10] [32]

A profile he never authorised, from prompts he thought were private – consequences he can’t take back.

It’s not just engineers.

A doctor pastes a patient note to draft a referral.	PHI · HIPAA
A lawyer pastes a contract to “just summarise it.”	privileged client data
A researcher pastes unpublished results to polish a draft.	embargo · subjects’ data
A government official pastes a citizen’s case file.	records-law exposure
A founder pastes the cap table to model a raise.	market-moving secrets

Swap the job and the story is identical – Min-jun is a developer, but he’s also **everyone**.

Now multiply this by everyone who treats AI like a private room.

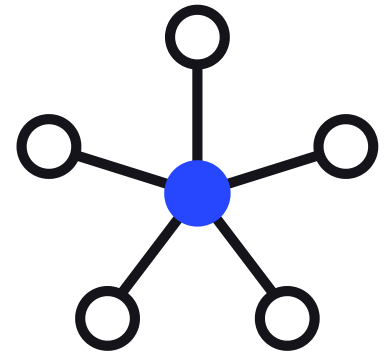
A private chat becomes a profile. Profiles become datasets. Datasets become models, targeting systems, risk scores, subpoenas, and attack surfaces.

The prompt stops being a message – it becomes a behavioral signal: what you fear, what you need, what you plan, what you hide, and when you're vulnerable.

04

Where it's exposed

The same data, leaking through five surfaces.



His week doesn't stay in the chat box.

"explain my mum's biopsy report in plain Korean"	→ Memory · kept across sessions
"why is this stack trace failing?" (+ an API key)	→ Training & your repo
"book my Chuseok ticket home before they sell out"	→ Agents · acting for you
"summarize this slack thread before i reply"	→ Context / RAG · more files
"clean up my résumé — don't change the dates"	→ Logs & retention

Five ordinary prompts → five different systems.
The next slides follow each one.

The longer you talk, the bigger the standing pool.

A chat is stateless, so the whole conversation is re-sent every turn — and retrieval quietly pulls your files in, surfacing secrets in up to ~27% of RAG-assistant chats in a privacy benchmark. [\[22\]](#)
[\[50\]](#)

Memory turns one chat into a permanent profile.

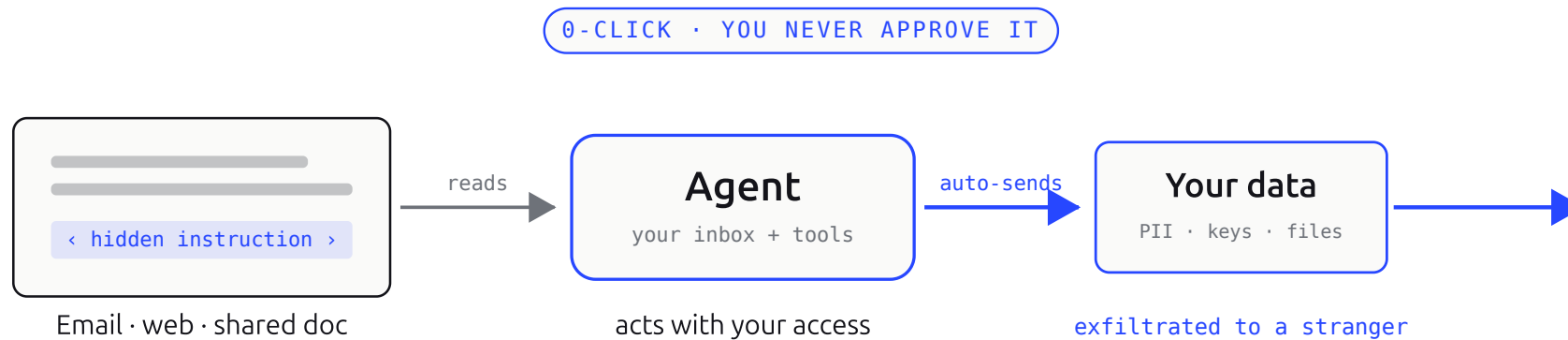
Built across sessions, stored server-side. Anyone holding your login can ask “what do you know about me?” — and injection can write to memory, then exfiltrate it. [\[49\]](#)

By default, many consumer chats train the next model.

Anthropic: 30-day retention unless you allow training — then up to [5 years](#). ^[15]

OpenAI: under court order it must preserve [deleted](#) chats ^[16]; separately, ~20M de-identified logs are at issue in the NYT case ^[40]. Gemini: human-reviewed, kept up to 3 years. ^[17] And “synthetic” data is no shield — fine-tuning on AI-generated data still leaks the source PII (up to ~44% more extractable). ^[32]

Agents don't just answer — they act.



Wired to your inbox and tools, one hidden instruction triggers [zero-click](#) exfiltration — EchoLeak, AgentFlayer, ShadowLeak.
[\[11\]](#) [\[12\]](#) [\[13\]](#) [\[51\]](#) [\[52\]](#)

Coding agents read your whole repo.

Claude Code, Cursor, Copilot ingest the workspace — .env files and keys ride along; CamoLeak exfiltrated private source, and AI-assisted commits leak secrets ~2× as often. [\[14\]](#) [\[18\]](#) [\[19\]](#) [\[53\]](#)

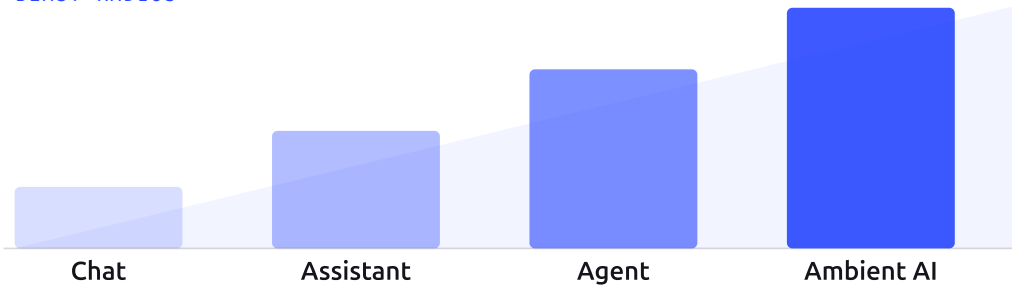
The assistant that holds everything.

A new wave of always-on personal assistants is moving from the chat window into your inbox, files, messages, calendar and browser — with persistent memory and your credentials (e.g. Jan, AnythingLLM, OpenClaw). [\[43\]](#)

Self-hosting removes one cloud provider — but it can create one overpowered local vault: your whole digital life at hobby-grade security, reachable by injection through any channel it touches; a poisoned “tool” server already BCC’d every email to an attacker. [\[46\]](#)

Chat was the easy case.

BLAST RADIUS →



Standing access

your inbox, files, calendar — not one pasted snippet

Less human review

it acts before you can check what it sent

Cross-app data flows

one task pulls from five services at once

Multi-agent chains

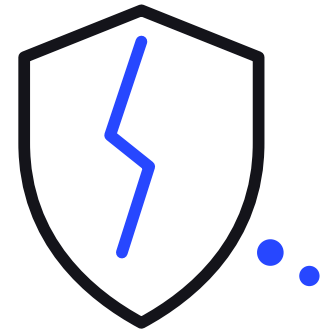
one leaked secret propagates downstream

The trend, not a forecast — 1B → 2.5B prompts/day in 8 months^[33], +485% corporate data into AI in 2 yrs^[34]; analysts expect agentic AI in ~40% of enterprise apps by 2026 (from <5%)^[36], and 75% of engineers on AI code assistants by 2028^[47]. It compounds with capability: chat leaks intent · assistants leak context · agents leak action · coding agents leak systems.

05

Where the defenses break.

A toolbox built for a different problem.



The toolbox today.

	Redaction	strip or mask PII before sending [20]
	Pseudonymization	swap in realistic fakes, restore on return [31]
	Differential privacy	add calibrated noise so no one stands out [20]
	Homomorphic encryption	compute over text the server can't read [23]
	Confidential computing	run prompts in a hardware enclave the provider can't read [48] [39]
	On-device / local LLMs	never send raw data to the cloud [21]
	Federated learning	train across devices without pooling data [20]

Most were built to scrub a single prompt – not memory, training, agents, or repos. [\[20\]](#)

Seven ways they break.

Local-model limits	on-device privacy costs intelligence & speed [21]
Coherence	hiding meaning breaks the model’s answer [20]
Residual leakage	redaction loses context; the shape still shows [29]
Multi-turn	inconsistent fakes re-link one identity [31]
Usability	detection misses PII; what’s missed leaks [21]
Context loss	redaction strips what the model needs to answer [20]
Cost	the strongest methods are too slow or heavy to run [23]

They cluster into three failures – capability you lose, meaning you break, identity that re-links. Worked examples next.

Keeping it local trades away capability.

YOU >

Find the race condition in this 2,000-line service and refactor it.

LOCAL >

[on-device 8B model] truncates the file, misses the bug, answers slowly.

Illustrative

Tradeoff – on-device never leaks, but smaller models reason worse, hold less context, and run slower; the hardest work pulls you back to the cloud. ^[21]

Hide the meaning, lose the answer.

YOU >

meet ☕🔑🌙 at 🏛️ re 📄 about 💰
(EMOJI-OBFUSCATED)

MODEL >

I'm not sure what you mean – which meeting, where,
and about what?

Illustrative

Tradeoff – the more you scramble text to hide it,
the less the model understands, so the answer
degrades. ^[20]

The shape still shows.

YOU >

Summarize this note from [NAME] at the [CITY] branch about [NAME]'s visa renewal.

MODEL >

Sure – this looks like Japanese immigration paperwork...

Illustrative

Tradeoff – redact more and you strip the context the model needs; redact less and the residue still re-identifies. [\[20\]](#) [\[29\]](#)

Identity re-links itself.

T1 >

Set up a call with John Smith.
→ SENT AS "MICHAEL BROWN"

T4 >

Did John get back to us?
→ "MIKE B."

T7 >

Forward John's contract.
→ "JOHN S."

OBS >

three aliases, one real person.

Illustrative

Tradeoff – per-turn redaction is simple and stateless, but inconsistent aliases across a chat re-link the very identity they hid. [\[31\]](#) [\[29\]](#)

What you miss, you leak.

YOU >

Bill account 4111 1111 1111 1111, contact Dr. R. Khan, MRN 88421.

FILTER >

✓ card masked ... ✗ missed “MRN 88421”

CLOUD >

Noted patient record MRN 88421 ... ← leaked

Illustrative

Tradeoff – automating detection cuts effort, but small/edge models catch only ~63% of PII vs ~88% for a frontier model – the misses ship.^[21]

Redact too much, and the answer falls apart.

YOU >

Is a glucose of [REDACTED] dangerous for a [REDACTED]-year-old on [REDACTED]?

MODEL >

Without the value, age, and medication, I can't tell you what's abnormal.

Illustrative

Tradeoff – aggressive redaction deletes the signal the model needs; it refuses or guesses, and users paste the raw data back in. ^[20]

Privacy you can't afford to run.

YOU >

What's a safe ibuprofen dose for my mother?

ENC >

[wrapped in homomorphic encryption]

MODEL >

...the answer comes back over 16 minutes later.

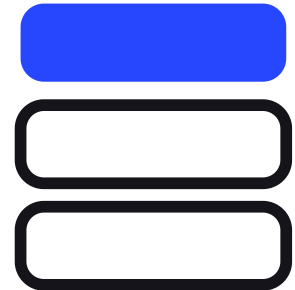
Illustrative

Tradeoff – the strongest cryptographic methods are real but ruinously slow: homomorphic encryption can take over sixteen minutes for a single inference, and local models need a GPU most people don't have. [\[23\]](#) [\[20\]](#)

06

What can be done

The good news: it's fixable at three levels — and you own the first.



You.

	Turn off training	disable history, or use enterprise / zero-retention tiers
	Don't paste secrets	no credentials, no whole documents, no other people's data
	Scrub before you paste	strip PII, or run a local pre-processor
	Keep the crown jewels local	use an on-device model for the sensitive work
	Prune memory	clear it; use temporary chats for one-off questions
	Assume it's logged	if you wouldn't email it to a stranger, don't prompt it

Small habits, big drop in exposure – you don't have to quit AI.

What builders owe you.

 Opt-out by default	no training on personal chats unless you clearly opt in
 Zero retention	short, transparent retention; “delete” that deletes
 Data minimization	don’t log or keep what the task doesn’t need
 On-device / confidential compute	do the sensitive work on the device, or in an enclave the provider can’t read [39] [48]
 Scoped agents	tools get the narrowest access, not the keys
 Transparency	show plainly what’s stored, for how long, and who can see it

The defaults are the policy.

Won't that break their business model?

Retention and training data are the moat — so why would they give it up?

Regulation	GDPR's €15M, Korea's PIPA, and the EU AI Act already bite [4] [28] [37]
Enterprise demand	B2B won't buy without zero-retention — ZDR & enterprise tiers already exist [38]
Trust as edge	privacy becomes a selling point — on-device & private compute [39]
Efficiency	on-device & minimization cut providers' own compute bill

Not charity – regulation, revenue, and cost. Some of it already ships.

And the research frontier.

Efficient private prompting	protection without heavy crypto or local LLMs [23]
Meaning-preserving sanitization	hide who it is, keep what it says [29]
Lightweight detection	accurate PII & secret spotting, on the edge [21]
Memory- & conversation-aware privacy	consistent across turns and profiles [31]
Retrieval-aware privacy	keep RAG from surfacing private context — privacy-aware decoding, selective disclosure [50]
Agent guardrails	least-privilege + system-level egress control, not just prompt filters [30] [51] [52]
Shared benchmarks	so methods are comparable and provable [22]

Open directions – building on the privacy-prompting literature. [\[20\]](#)

Where the law stands.

 EU · GDPR	access, deletion, consent with teeth — Italy fined OpenAI €15M [4]
 India · DPDP	passed 2023; Rules notified 2025, phased compliance into 2027 [27]
 South Korea · PIPA	the PIPC fined Scatter Lab over Lee Luda — and now polices AI [28]
 US · patchwork	CCPA/CPRA only [54] ; HIPAA covers hospitals, not your chatbot [55]

Rights exist on paper; enforcement lags the technology, and “delete” often won’t reach backups, logs, legal holds, training sets, or downstream copies.

You can keep the convenience — and cut the exposure.

Your prompts are the most honest record of who you are — intent, context, memory, and permission. As AI moves from chat to agents, the exposure surface grows faster than habits or regulation.

The problem is defined; the solution space is open. This isn't anti-AI — it's pro-control.

References.

- [1] [OpenAI Redis bug, Mar 2023 · thehackernews.com](#)
- [2] [Samsung bans generative AI, May 2023 · theregister.com](#)
- [3] [Italy Garante halts ChatGPT, Mar 2023 · cliffordchance.com](#)
- [4] [Garante fines OpenAI €15M, Dec 2024 · thehackernews.com](#)
- [5] [Wiz — exposed DeepSeek database, Jan 2025 · wiz.io](#)
- [6] [Fortune — ChatGPT shared chats indexed, Aug 2025 · fortune.com](#)
- [7] [Scatter Lab / Lee Luda fined, 2021 · theregister.com](#)
- [8] [Bing “Sydney” prompt injection, Feb 2023 · techspot.com](#)
- [9] [Wiz — 38TB exposed by Microsoft AI, Sept 2023 · wiz.io](#)
- [10] [Carlini et al., extraction attack, 2023 · arXiv:2311.17035](#)
- [11] [EchoLeak \(CVE-2025-32711\), Jun 2025 · securiti.ai](#)
- [12] [Zenity Labs — AgentFlayer, Aug 2025 · zenity.io](#)
- [13] [Radware — ShadowLeak, Sept 2025 · radware.com](#)
- [14] [Legit Security — CamoLeak \(CVE-2025-59145\), Oct 2025 · legitsecurity.com](#)
- [15] [Anthropic — Updates to Consumer Terms, Aug 2025 · anthropic.com](#)

References.

- [16] [OpenAI — Response to NYT data demands, 2025 · openai.com](#)
- [17] [Google — Gemini Apps Privacy Hub · support.google.com](#)
- [18] [GitGuardian — State of Secrets Sprawl 2025 · gitguardian.com](#)
- [19] [Check Point / Knostic — coding assistants leak secrets, 2025 · developer-tech.com](#)
- [20] [Edemacu & Wu — Privacy-Preserving Prompt Engineering: A Survey, 2025 · arXiv:2404.06001](#)
- [21] [Zhou et al. — Rescriber, CHI 2025 · arXiv:2410.11876](#)
- [22] [Mukhopadhyay et al. — PrivacyBench, 2025 · arXiv:2512.24848](#)
- [23] [Preempt — Sanitizing Sensitive Prompts for LLMs, 2025 · arXiv:2504.05147](#)
- [24] [Cyberhaven — confidential data pasted into ChatGPT, 2023–24 · cyberhaven.com](#)
- [25] [LayerX — Enterprise AI & SaaS Data Security Report 2025 · theregister.com](#)
- [26] [ChatGPT nears 1B weekly users \(≈900M\), Feb 2026 · 9to5mac.com](#)
- [27] [India MeitY — DPDP Act 2023 + Rules 2025 · pib.gov.in](#)
- [28] [Korea PIPC — PIPA & the Lee Luda case \(2021\) · fpf.org](#)
- [29] [Yang et al. — Robust Utility-Preserving Text Anonymization \(RUPTA\), ACL 2025 · aclanthology.org](#)
- [30] [Geng et al. — PISanitizer, 2025 · arXiv:2511.10720](#)

References.

- [31] [Park & Madisetti — CAPRI: Context-Aware Privacy for Multi-Agent GenAI, IEEE Access 2025 · ieee.org](#)
- [32] [Akkus et al. — Generated Data with Fake Privacy, USENIX Security 2025 · usenix.org](#)
- [33] [ChatGPT users send 2.5B prompts/day, Jul 2025 · techcrunch.com](#)
- [34] [Cyberhaven Labs — 2025 AI Adoption & Risk Report](#)
- [35] [IBM — Cost of a Data Breach 2025 \(shadow-AI findings\)](#)
- [36] [Gartner — ~40% of enterprise apps to feature AI agents by 2026 \(forecast\)](#)
- [37] [European Commission — EU AI Act \(in force Aug 2024\) · ec.europa.eu](#)
- [38] [OpenAI — Enterprise privacy & Zero Data Retention · openai.com](#)
- [39] [Apple — Private Cloud Compute: private AI in the cloud · security.apple.com](#)
- [40] [Court orders OpenAI to produce ~20M de-identified ChatGPT logs \(NYT case\) · natlawreview.com](#)
- [41] [Meta to use AI-chatbot conversations for ad targeting, Oct 2025 · cnn.com](#)
- [42] [FTC — staff report on commercial surveillance & data brokers, Sept 2024 · ftc.gov](#)
- [43] [OpenClaw — self-hosted personal AI assistant, 2025 · github.com](#)
- [44] [Slack AI data exfiltration via prompt injection, Aug 2024 · theregister.com](#)
- [45] [Replit AI agent deleted a production database, Jul 2025 · theregister.com](#)

References.

- [46] [First malicious MCP server \(postmark-mcp\) BCC'd emails, Sept 2025 · thehackernews.com](#)
- [47] [Gartner — 75% of enterprise software engineers on AI code assistants by 2028 · gartner.com](#)
- [48] [Confidential Prompting — privacy-preserving LLM inference on cloud, 2025 · arXiv:2409.19134](#)
- [49] [Wang et al. — Unveiling Privacy Risks in LLM Agent Memory \(MEXTRA\), ACL 2025 · arXiv:2502.13172](#)
- [50] [Privacy-Aware Decoding — mitigating RAG privacy leakage, 2025 · arXiv:2508.03098](#)
- [51] [Simple prompt-injection leaks personal data via LLM agents, 2025 · arXiv:2506.01055](#)
- [52] [Silent Egress — implicit injection makes agents leak, 2026 · arXiv:2602.22450](#)
- [53] [Prompt-leaking attacks in real-world LLM apps \(≈80% leak\), 2026 · arXiv:2606.18673](#)
- [54] [IAPP — US State Privacy Legislation Tracker \(state patchwork\) · iapp.org](#)
- [55] [HHS — HIPAA covered entities \(who must comply\) · hhs.gov](#)
- [56] [CFPB — proposed Data Broker rule: employment & income data sold as consumer reports, Dec 2024 · federalregister.gov](#)
- [57] [FTC — “Data Brokers: A Call for Transparency & Accountability” \(financially-vulnerable lists\), May 2014 · ftc.gov](#)
- [58] [FTC — GoodRx shared users' prescription & health-condition data with Facebook/Google, Feb 2023 · ftc.gov](#)
- [59] [Verizon — 2024 Data Breach Investigations Report \(social engineering & pretexting\) · verizon.com](#)

More numbers, for the record.

1 in 4

workplace AI pastes are sensitive ^[24]

>1M

DeepSeek log lines (chats + keys) left public ^[5]

~20M

ChatGPT logs ordered for production (NYT case) ^[16] ^[40]

65%

of shadow-AI breaches exposed customer PII ^[35]

≤44%

more PII extractable after synthetic-data fine-tuning ^[32]

1.2%

of ChatGPT Plus users hit by the Redis leak ^[1]

485%

rise in corporate data flowing into AI (2 yrs) ^[34]

97%

of AI-breached orgs lacked AI access controls ^[35]

